

# Digital Policy Office

---

## INFORMATION SECURITY

---

### Practice Guide for Data Loss Prevention

Version 1.3

July 2024

© The Government of the Hong Kong Special Administrative Region  
of the People's Republic of China

The contents of this document remain the property of and may not be reproduced in whole or in part without the express permission of the Government of the Hong Kong Special Administrative Region of the People's Republic of China.

## **COPYRIGHT NOTICE**

© 2024 by the Government of the Hong Kong Special Administrative Region of the People's Republic of China

Unless otherwise indicated, the copyright in the works contained in this publication is owned by the Government of the Hong Kong Special Administrative Region of the People's Republic of China. You may generally copy and distribute these materials in any format or medium provided the following conditions are met –

- (a) the particular item has not been specifically indicated to be excluded and is therefore not to be copied or distributed;
- (b) the copying is not done for the purpose of creating copies for sale;
- (c) the materials must be reproduced accurately and must not be used in a misleading context; and
- (d) the copies shall be accompanied by the words “copied/distributed with the permission of the Government of the Hong Kong Special Administrative Region of the People's Republic of China. All rights reserved.”

If you wish to make copies for purposes other than that permitted above, you should seek permission by contacting the Digital Policy Office.

| Amendment History |                                                                                                                                                                                                                        |                                |                 |             |
|-------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------|-----------------|-------------|
| Change Number     | Revision Description                                                                                                                                                                                                   | Pages Affected                 | Revision Number | Date        |
| 1                 | Revised in accordance with the classification of Security Regulations (SRs)                                                                                                                                            | 14 - 17                        | 1.1             | August 2020 |
| 2                 | Updates were made on the requirements to strengthen security protection on the use of removable media and printers in Section 2.3.2, Section 2.3.2.2, Section 2.3.2.3, Section 2.3.2.5, Section 3.2.2 and Section 3.6. | 9, 13-15, 19, 22-24, 35, 47-48 | 1.2             | June 2021   |
| 3                 | Change “Office of the Government Chief Information Officer” (or “OGCIO” ) to “Digital Policy Office” (or “DPO”)                                                                                                        |                                | 1.3             | July 2024   |

## Table of Contents

|     |                                                                    |     |
|-----|--------------------------------------------------------------------|-----|
| 1.  | Introduction.....                                                  | 1   |
| 1.1 | Purpose.....                                                       | 1   |
| 1.2 | Normative References.....                                          | 1   |
| 1.3 | Terms and Convention.....                                          | 2   |
| 1.4 | Contact.....                                                       | 2   |
| 2.  | Data Loss Prevention .....                                         | 3   |
| 2.1 | Type of Data Loss.....                                             | 3   |
| 2.2 | Three States of Data.....                                          | 3   |
| 2.3 | Three Elements of DLP .....                                        | 4   |
| 3.  | Layers of Defence .....                                            | 21  |
| 3.1 | Known Intrusions.....                                              | 25  |
| 3.2 | Zero-day Web Attack.....                                           | 30  |
| 3.3 | Spear-phishing Email Attack .....                                  | 36  |
| 3.4 | Offline Data Leakage.....                                          | 41  |
| 3.5 | Mobile Data Leakage.....                                           | 44  |
| 3.6 | Data Leakage via Removable Media and Printers.....                 | 47  |
|     | Annex A: Considerations on Server and Workstation Backup Plan..... | A-1 |
|     | Annex B: Advanced Persistent Threats (APT) .....                   | B-1 |

## 1. Introduction

Data is a valuable asset to the Government and loss of sensitive data to the wrong hands would have significant impact on the Government's reputation. This practice guide is developed to provide best practice on data loss prevention (DLP) solutions for B/Ds reference to enhance data security.

### 1.1 Purpose

The purpose of this document is to provide general guidance notes and some best practices on DLP, and the layers of defence (also known as defence-in-depth) principle as a synergy approach to enhance the overall data security protection for the Government. The layers of defence consists of two levels: network gateway level and departmental level. Different security controls can be considered in either (or both) level in order to address the common security threats that may lead to potential loss, leakage or destruction of classified information.

This practice guide also addresses security considerations on data management from the risk of data loss perspective. Guidance notes are provided to B/Ds to implement an effective DLP and layers of defence with the aim at minimising the risk of loss, leakage or damage of classified data

This document should be used in conjunction with established Baseline IT Security Policy, Security Guidelines and relevant procedures, where applicable. The general guidance notes represent what are regarded as best practices to maintain security risks at an acceptable level. It is intended for staff who are involved in the use of IT systems and facilities.

### 1.2 Normative References

The following referenced documents are indispensable for the application of this document.

- Baseline IT Security Policy [S17] , the Government of the Hong Kong Special Administrative Region
- IT Security Guidelines [G3] , the Government of the Hong Kong Special Administrative Region
- Security Regulations [SR]
- Information technology – Security techniques – Information security management systems – Requirements, ISO/IEC 27001:2013
- Information technology – Security techniques – Code of practice for information security controls, ISO/IEC 27002:2013
- Information technology – Security techniques – Governance of information security, ISO/IEC 27014:2013

- Information technology – Security techniques – Network security, ISO/IEC 27033:2015
- Information technology – Security techniques – Specification for digital redaction, ISO/IEC 27038:2014
- Information technology – Security techniques – Storage security, ISO/IEC 27040:2015

### 1.3 Terms and Convention

For the purposes of this document, the terms and convention given in S17, G3, and the following apply.

| Abbreviation and Terms |    |
|------------------------|----|
| NA                     | NA |

### 1.4 Contact

This document is produced and maintained by the Digital Policy Office (DPO). For comments or suggestions, please send to:

Email: [it\\_security@digitalpolicy.gov.hk](mailto:it_security@digitalpolicy.gov.hk)

Lotus Notes mail: [IT\\_Security\\_Team/DPO/HKSARG@DPO](mailto:IT_Security_Team/DPO/HKSARG@DPO)

CMMP mail: [IT\\_Security\\_Team/DPO](mailto:IT_Security_Team/DPO)

## **2. Data Loss Prevention**

DLP is the practice of detecting and preventing classified data from being leaked out of an organisation's boundaries for unauthorised use. Any data loss incident would be undesirable to the Government and/or public. Proper security measures should be in place to minimise the risk. There exists many DLP technical solutions, but those alone may not prevent data loss effectively. An effective DLP programme should consist of people's security awareness, security process and technical security measures.

### **2.1 Type of Data Loss**

Data loss can be caused by unintentional, intentional and malicious loss to unauthorised party. The consequence of data loss impacts data confidentiality, integrity and availability.

Unintentional loss refers to disclose information to others unintentionally by carelessness; typical examples include the loss of removable storage media, mobile devices, or paper documents containing classified data.

Intentional loss refers to disclose information to others by disregard of information security policy; typical examples include transmitting classified data over un-trusted network without encryption, sending email to unauthorised parties, or bypassing security check of attachments in email by alternating the file extension which may not be identified by generic data protection solutions.

Malicious loss refers to disclose information to hackers deliberately and illegally by technology loophole and social engineering that the unauthorised revealed classified data will be used for specific purpose; typical examples include Trojan horse programs, malware, phishing emails/website, ransomware, and insider attack.

### **2.2 Three States of Data**

Data loss is not an infrastructure or network problem; it is about protecting the data where it is at the greatest risk – whenever and wherever it is in use. Data should be protected in the three states: data at rest, data in motion, and data in use. Each of these three states of data is addressed in the following subsections with a specific set of technologies provided by a single or multiple technical solutions. B/Ds have the flexibility to select technical controls to protect the information at all three states according to their specific needs.

**Data at Rest**

Data at rest refers to data that is stored within the IT infrastructure and on media. Common components containing data at rest are servers, databases, file shares, intranet sites, workstations, laptops, mobile devices, and backup tapes, cloud computing and removable media.

**Data in Use**

Data in use refers to data that is being accessed or used by a system at a point in time. Common examples include data in temporary memory or random access memory on a local machine, an open document or running query on a workstation, an email that has been drafted but not sent, data being copied and pasted from one local document to another, or a file being copied or printed.

**Data in Motion**

Data in motion refers to data that is being transmitted over network, such as flowing across internal networks, Internet or between the B/Ds.

## 2.3 Three Elements of DLP

There is no single solution that can be implemented to perfectly address all potential risks of data from being unintentional, intentional and malicious leaked. A comprehensive DLP solution should consider all three indispensable elements: people, process and technology. In other words, for DLP to be effective, B/Ds must engage the right people, establish the right process, and employ the right technology. Here are some guidelines and considerations derived from these elements:

### 2.3.1 People

According to study<sup>1</sup>, organisation may find that the majority of data loss risks are associated with staff inside the organisation who unconsciously put data at risk in the course of their daily operation at work. These can include staff mishandling information, violations of industry and government regulations, inadvertent data dumps, stolen laptops, and wrongful access.

For the above reason, it is crucial for staff to understand or feel accountable for the protection of classified data which they held and processed. Staff security awareness and their roles and responsibilities in data security should be promoted and defined clearly in order to address the data loss risks brought by people.

---

<sup>1</sup> <http://www.symantec.com/content/en/us/about/media/pdfs/b-cost-of-a-data-breach-us-report-2013.en-us.pdf>



### 2.3.1.1 Assign Roles and Responsibility

To have an effective DLP process, the roles and responsibilities of supporting data security personnel are suggested as below:

- a) Information Owner - The collator and the owner of information stored in information systems who is responsible for determining the data classifications, the authorised data usage, and the corresponding security requirements for protection of the information based on the business and government security requirements. Information owner is also responsible for reviewing the appropriateness of the classifications for the existing data regularly.
- b) User - People who actually use the information and shall be accountable for all their activities. Particularly, anyone who has access to government data and require to observe and follow the defined security requirements and policies in using the data. The example of this role is government staff.
- c) Data Custodians – Anyone who is responsible for providing adequate protection of data defined by the information owner. The example of the role includes system administrator, database administrator, infrastructure architect, LAN/System Administrator, and Application Development & Maintenance Team.

By above definition, it is possible to have same person with two or more roles simultaneously. Example is a government staff owned a document as he/she created and use the same document simultaneously. Thus, the government staff need to determine the data classification and follow the security requirements such as storing, processing and transmitting classified information.

### 2.3.1.2 Promotion of Security Awareness of the Data Security Requirements

In order to promote the security awareness of data security requirements in an organisation, an effective way is continuous information sharing such as distribution of security news or supplement especially right after major changes of security requirements in IT security documents and/or major security incident that has severe impact to the Government and/or public. The followings are guidelines of distributing security news or supplement for B/Ds as reference:

- a) All requirements are well-documented. Audience should be educated where the related documents including precedence of them could be found;
- b) General principles should be delivered to the audience so that they could understand and remember the main ideas easily;
- c) Do's and Don'ts with practical examples may also raise the audience's interest and can solidify their understanding; and
- d) The size of the supplement should be kept as short and precise as possible. For example, around five pages for regular issues and one to two pages for a reminder after major incident or any potential incident of high likelihood.

### 2.3.1.3 Security Awareness Training

Human error was one of the major causes of data breach in terms of financial loss. To help decrease the opportunity of occurrence of this cause, the most effective way is to conduct security awareness training so as to educate people on the preventive and responsive handling on the latest crime, and incidents of disregard or negligence.

Imprudence is the fundamental cause of many security incidents. While technology controls help in mitigating the risk, B/Ds should take proactive measures to educate users about their risk and potential impacts. Stakeholders, including senior management, supervisors and users, should have their roles and responsibilities defined in order to promote the security awareness and strengthening the data security. The suggested roles and responsibilities are as below for B/Ds as reference to develop their owned organisation model.

#### *Senior Management*

- a) Develop and review regularly the departmental information security policies and guidelines in data handling;
- b) Direct and enforce the development of security measures;
- c) Derive IT security education and training plans;
- d) Organise activities to promote staff awareness with examples as below:
  - Conduct security awareness training, workshops and internal briefing;
  - Encourage staff to attend security briefing and seminars;
  - Issue instructions and guidelines and remind staff by regular circulation;
  - Organise induction courses for new staff and contractors including the introduction of security policies, guidelines, circulars, government security workflow and process;
  - Provide information packs and briefing to new staff and contractors;
  - Send regular electronic messages to remind staff on security requirements; and
  - Use security tips and screen savers to remind users.
- e) Provide the necessary resources required for the security measures to be implemented; and
- f) Ensure participation of all levels of staff including management, administrative, technical and operational staff.

#### *Supervisors*

- a) Educate staff on proper ways to handle data and special cautions to be taken when handling classified data;
- b) Provide a secure way of transferring and accessing data;
- c) Enforce IT security policies and regulations;
- d) Monitor the compliance status of staff on policies and regulations related to data protection closely;

- e) Implement the data protection measures in accordance with security policy, guidelines and procedures; and
- f) Report to Departmental IT Security Officer (DITSO) or Departmental Security Officer (DSO) immediately if there is any security incident or data loss.

### *Users*

- a) Understand and comply with related information security policy and regulations;
- b) Understand their roles and responsibilities;
- c) Understand the consequences of data loss; and
- d) Follow the administrative procedures and apply all possible and available security mechanisms for data protection.

## 2.3.2 Process

To effectively manage the risk of data loss, a holistic DLP process (strategy) should be developed to ensure that the combination of controls complement each other in order to protect classified data that the B/D holds in an all-rounded approach.

Before developing an effective DLP strategy, the following questions should be considered at the beginning:

- i. What data are regarded as classified data?
- ii. Where do the classified data reside?
- iii. What are the potential risks and impact?
- iv. What appropriate controls can be applied to contain the risks?

A comprehensive DLP strategy consists of following components:

- Inventory and Risk Assessment
- Policy and Data Classification
- Discovery
- Implement Controls
- Data Backup and Recovery Plan
- Monitor, Manage and Improve

### **Inventory and Risk Assessment**

Identify data that needs protection and analyse the risk impact. Data with high impact can be identified first and the acceptable risk level for information should be assessed. As part of risk analysis, B/Ds should assess and evaluate existing possible channels in which classified data is shared with third parties as well.

**Policy and Data Classification**

Existing data classifications and security requirements in the Government, information security requirements in the departmental information security policy, the Baseline IT Security Policy and other relevant policies and guidelines should be observed and followed. In particular, Section 2.3.2.1 would provide some specific security requirements for handling or using data in connection with a data life cycle.

Besides, B/D should regularly update the inventory of their data categorised by data classification. The classification of data should be based on level of sensitivity.

After the data classification process, the data identified as classified information can be categorised based on its level of sensitivity.

**Discovery**

Discover and document data assets and the current controls on them. Determine how to recognise classified data, whether it is used, stored or transmitted.

**Implement Controls**

Access to application and data, especially classified data, should be restricted to those who are authenticated and authorised to access. Proper data protection controls such as access control and encryption should be adopted to contain the risks. These controls include administrative procedures and technical measures to safeguard data. It is important to note that a threat scenario may ultimately lead to a data leakage incident. A risk-based approach should be taken to identify possible threat scenarios and associated security risks. Adequate security measures should be in place to mitigate the impact and likelihood of the identified threat scenarios. The following are some examples of protection controls to against the common threat scenarios:

| Threat Scenario                                                                                                             | Examples of Protection Controls                                                                                                                                                                                |
|-----------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Unauthorised access of the application or data.                                                                             | Encrypted password system, magnetic cardkey system, challenge and response system, digital signature, file permission, access control, restricted access to backup data, audit log, or a combination of these. |
| Unauthorised access of the workstation or terminal.                                                                         | Keyboard lock, screen saver with password protection, bootup password and proper access control.                                                                                                               |
| Unauthorised access of mobile devices or removable media.                                                                   | System with encryption capability, proper access control, and safe custody.                                                                                                                                    |
| Unauthorised information transmission to removable media or printers.                                                       | Logging printing activities and file transfer activities to removable media, restricting connection of unauthorised removable media.                                                                           |
| Disclosure of information on screen.                                                                                        | User profiles and views, screen saver with password protection, proper positioning of the display screen, timer to disconnect.                                                                                 |
| Disclosure of information on transmission.                                                                                  | Secure communication and authentication protocols, such as challenge and response authentication and Transport Layer Security (TLS) protocol.                                                                  |
| No service due to server failure.                                                                                           | Tape backup system, mirror disk, redundant array of independent disks (RAID) system, server backup system, hot standby system.                                                                                 |
| No service due to communication link failure.                                                                               | Multiple communication paths.                                                                                                                                                                                  |
| Spoofing of origin (someone sends the message in others name).                                                              | Multiple authentication mechanism, digital signature.                                                                                                                                                          |
| Spoofing of delivery (someone sends the message but denies afterwards or someone makeup the message which he did not send). | Transaction log, message time stamp, digital signature.                                                                                                                                                        |
| Spoofing of receipt (someone pretends he has not read the message in which he actually did).                                | Multiple authentication mechanism, transaction log, message send/read time stamp, return receipt.                                                                                                              |

Sections 2.3.2.2 – 2.3.2.4 would provide more general controls for protecting data at rest, data in use and data in motion. Measures for protecting data under certain specific circumstances would be provided in Sections 2.3.2.5.

**Data Backup and Recovery Plan**

A good data backup and recovery plan is an essential component of the data loss prevention strategy. File system backups not only protect data in the event of hardware failure or accidental deletions, but also protect information systems against unauthorised changes made by an intruder. With a daily copy of data backup, it would be easier to revert to the last secured state of information systems prior to the changes or modifications an intruder has made. Backup media containing business essential and/or mission critical information shall be disconnected from information systems. This protects the backup media from being tampered with when the information systems are compromised. A copy shall also be sited at a secure and safe location remote from the site of the equipment for data recovery when a disaster occurs in the main site.

Backups, especially if run daily, can also be useful in providing a history of an intruder's activities. Looking through old backups can provide footprints when the system was first penetrated. Intruders may leave files around which, although deleted later, are captured on the backup media.

Some considerations on preparing a data backup plan for server and workstation are provided in the Annex A for reference.

**Monitor, Manage and Improve**

Monitor the environment and enforce the compliance with policy and regulations. Regular reviews at different stages and processes are necessary to adjust the rules and controls.

### 2.3.2.1 Data Life Cycle Management

Data life cycle management is a policy and procedure based approach to managing data throughout its life cycle: from creation and initial storage to the time when it becomes obsolete and is destroyed. It aims to provide framework for data management and provide cost effective solution for risk mitigation, and to reduce the risk of data loss or leakage. The life cycle includes six phases, namely create, store, use, share, archive and destroy. Appropriate procedures and practices should be deployed to properly protect the data at different phases.

**Create:** It applies to creating or changing a data or content element. Creation is the generation of new digital content or the alteration/updating of existing content, either structured or unstructured. In this stage the information should be classified and appropriate security measures should be determined.

**Store:** It refers to the act of committing data to structured or unstructured storage, such as database or files. Appropriate security controls, including access controls, encryption and rights management, commensurate with the classification of the data should be applied to managing content in storage repositories.

**Use:** It refers to the stage when the user is interacting with the data. Security controls should be deployed to ensure the access of data in a manner that conform to government security requirements. Data access and usage activities should be properly monitored, and if possible with preventive measures to alert/stop policy violations.

**Share:** It refers to the stage when exchanging data with users or external parties. Secure sharing of data should be ensured by deploying appropriate encryption technology. A mix of detective and preventative measures, such as by deploying Data Loss Prevention (DLP) or Content Management Framework solutions, should be considered to monitor communications and block policy violations, in addition to monitor the activities related to data exchange.

**Archive:** It is a process of transferring data from active use into long-term storage. A combination of encryption and asset management should be used to protect the data and ensure its availability.

**Destroy:** When the data is no longer needed, it should be permanently destroyed. Verification should be done to ensure the data in all active storage or archives has been destroyed. Common techniques include shredding, disk/free space wiping or physical destruction.

Following are some of the security requirements for handling or using data in connection with a data life cycle:

| Phases of Data Life Cycle | Security Requirements                                                                                                                                                                                                                                                                                                                                                                                                                           |
|---------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Create                    | <ul style="list-style-type: none"><li>• Assign proper data classification to the data.</li><li>• Specify necessary security measures for the data, commensurate with the data classification as well as other contractual or legal requirements.</li><li>• Determine whether classification marking is needed.</li><li>• Determine the retention period for the data.</li></ul>                                                                 |
| Store                     | <ul style="list-style-type: none"><li>• Do not store classified information in privately-owned computer resources.</li><li>• Encrypt classified information during storage.</li></ul>                                                                                                                                                                                                                                                           |
| Use/Share                 | <ul style="list-style-type: none"><li>• Apply need-to-know and least privilege principles when need to access the data.</li><li>• Encrypt classified information during transmission.</li><li>• Track all activities in relation to share access of CONFIDENTIAL or above information by audit trail and logical access control software.</li><li>• Review the properness of information classification when information is modified.</li></ul> |
| Archive                   | <ul style="list-style-type: none"><li>• Apply same security controls as "Store", when putting classified information into archives.</li><li>• Maintain a record of repositories where classified information being stored.</li></ul>                                                                                                                                                                                                            |
| Destroy                   | <ul style="list-style-type: none"><li>• Ensure completely clear all classified information on media before disposal, or re-use.</li><li>• Perform proper data sanitisation by overwriting or degaussing, or physical destruction if necessary to prevent recovery of the classified information. Please refer to IT Security Guidelines Section 10.3(b) for details.</li></ul>                                                                  |



### 2.3.2.2 General Controls for Protecting Data at Rest

- a) Encrypt all classified information in storage.
- b) Only store classified information in approved removable media or mobile devices.
- c) Maintain inventory list of all removable media and mobile devices storing classified information with regular stock taking.
- d) Classified information must be kept with appropriate physical and logical protection or with proper attendance.
- e) For keys that are used for the processing of classified information that is highly sensitive, they must be stored separately from the corresponding encrypted information. The key length must be long enough to protect the corresponding data it encrypted, for example, 128-bit for AES encryption in symmetric encryption, or 2048-bit for the RSA encryption in asymmetric encryption.
- f) Removable media on which classified information is stored must be properly labelled.
- g) Restrict connection of unauthorised removable media to information systems containing classified data.
- h) Staff in possession of mobile device or removable media for business purposes shall safeguard the equipment in his/her possession, and shall not leave the equipment unattended without proper security measures.
- i) Implement security by default for system/server/workstation – for example, enable encryption feature at disk level during system setup so that encryption is enabled without further manual effort.
- j) Incorporate security by design during system development, for example, include data anonymisation<sup>2</sup>, tokenisation<sup>3</sup> and pseudonymisation<sup>4</sup> to protect personal information, if applicable. Encrypt key field(s) to protect confidentiality of information at application or database level.

---

<sup>2</sup> Data anonymisation is the process of turning data into a form such that the identification of individuals is not likely to take place.

<sup>3</sup> Data tokenisation is the process by replacing sensitive data element with substitutes without extrinsic meaning, usually refers as token. This token can be mapped back to sensitive data afterwards.

<sup>4</sup> Data pseudonymisation is the process by replacing personally identifiable information within a data record with one or more artificial identifiers, called pseudonyms. The pseudonyms makes the personal data less identifiable from the data record while remaining suitable for data analysis and data processing.

### 2.3.2.3 General Controls for Protecting Data in Motion

- a) Data transmission must be protected by a secure transmission channel.
- b) Sensitive information must be encrypted when transmitted over an un-trusted communication network. Setup Virtual Private Network (VPN), private key encryption, HTTPS to provide encryption at network level to protect data in motion.
- c) Setup web server to enable encryption by default (e.g. HTTPS) to ensure data transmission from web server to client is encrypted.

### 2.3.2.4 General Controls for Protecting Data in Use

- a) Restrict access to information systems containing information classified CONFIDENTIAL or above by means of logical access control.
- b) Enable audit trail for access to classified information and conduct regular check.
- c) Restrict file transfer activities to removable media for information systems containing classified information.
- d) Prevent unintentional viewing of classified data by external parties when reading or accessing classified information, in particular in public areas.
- e) After a file with classified data is processed in any temporary workstation ( such as user owned computer or internal share-use computer), user should remove the file, its temporary file(s) and the respective program cache file(s) during the processing completely from the file directory and inside recycle bin of that operating system.
- f) The printing of classified information should be properly controlled.

### 2.3.2.5 Data Protection Measures for Specific Scenarios

#### **For using Portable Electronic Storage Devices**

In view of the small size and high capacity of portable electronic storage devices, they may be easily lost or accessed by unauthorised parties inadvertently. These devices may be used for transient purpose only and should not be used as permanent storage especially for classified data. Storage of classified data to these devices should be authorised. Removable media provided by B/Ds should be used and the data in the removable media should be securely deleted immediately after use.

Following are the security measures that users of portable electronic storage devices require to pay attention to:

- a) Use portable electronic storage device with built-in encryption feature enabled. Other security features such as password locking with strong password that will destroy the data automatically after several attempts should also be implemented whenever possible.
- b) Scan for malware on removable media or storage media before use/copy.
- c) Classification marking should be firmly fixed on the device to clearly identify the classification of the data stored.
- d) Ensure the device is used under safe custody. Never leave the device unattended and it must be removed from computer immediately after use/copy.
- e) Do not share the device with or borrow it from others.
- f) Delete securely the classified information in the device and any duplicated copies stored on the PC or notebook immediately after use.

#### **For using Mobile Devices**

Users may copy data to mobile devices such as notebook computers, mobile phones, smartphones and take them away from office for working.

Mobile devices possess storage, processing and communication capabilities. They can be easily accessed by unauthorised parties or lost. The following should be aware of when using the mobile devices:

- a) Ensure the mobile device is under safe custody and auto locking feature is enabled if available.
- b) Enable the encryption feature to protect information where appropriate. (e.g.

full storage/disk encryption, file/folder encryption)

- c) Turn off wireless connections such as Wi-Fi or Bluetooth when the device is not in use and disable automatic connection with other devices, if available.
- d) Do not share the mobile device with others.
- e) Anti-malware software, where applicable, is installed and enabled with up-to-date signatures and real-time protection.
- f) Turn on personal firewall if available. Latest security patch of operating system and applications shall be installed.
- g) Delete securely any classified information and temporary copies after use.
- h) Do not leave the mobile device unattended without proper security measures.
- i) Select an appropriate working environment and position the display screen properly to prevent unauthorised persons from viewing the displayed information. Privacy screen filter should be adopted to limit the view angle of the display screen if necessary.

### **For using Remote Connections or Electronic Communication**

From home or remote location, users may be able to connect to office using Virtual Private Network (VPN) through the Internet and work on classified information. They may also communicate and transfer data through e-mail or other available communication channels.

Network connections outside office, e.g. Internet, are not secure and may be captured by others. Users should be aware of the potential risks and take proper measures to protect data:

- a) All classified data should be encrypted and securely transferred. Use of vulnerable protocols such as Point-to-Point Tunnelling Protocol (PPTP) and Secure Sockets Layer (SSL) 3.0 should be prohibited.
- b) Use dedicated officially provided computers or equipment when connecting to the office with security protections properly configured.
- c) Do not access or process classified information in public areas such as cybercafé or via public wireless connections.
- d) Do not store any classified information on public servers or transmit the information via public e-mail systems.

- e) Do not use any peer-to-peer file-sharing applications such as Foxy.
- f) Disable connection to other network before connecting to office network.
- g) Protect computers with password-enabled screen saver and never leave them connecting to office while unattended.
- h) Do not leave temporary working files in computers or equipment after connecting to office. It is a best practice to delete temporary data at log off or/ shut down by enabling such the built-in function of the equipment if applicable, or implementing secure deletion solutions.

### **For Secure Printing**

Hardcopies are often found in the printing device's output tray unprotected, leaving unattended printed documents susceptible to unauthorised access. An uncontrolled printing environment may introduce risk to confidentiality of classified documents. B/Ds should take practical precautions to protect documents which are printed, scanned, copied or faxed.

Secure printing is to ensure that (a) printing devices are secured; and (b) printed or transmitted data meets the confidentiality, integrity and availability requirements. Following practices should be adopted to secure the documents when using such devices:

- a) Physically secure the printing device. In particular, prevent unauthorised access to the storage device, e.g. hard drive, if any.
- b) The global configuration should be protected from unauthorised access. It should be modified via the console by requiring a strong password.
- c) Limit print/copy/fax/scan services to required protocols. Disable all unnecessary protocols/services.
- d) Require user authentication for printing classified documents, if available.
- e) Enable available security features on the device. For example, configure the device to remove spooled files and other temporary data using a secure overwrite, or encrypt the disk for data processing.
- f) Follow requirements as stipulated in government security requirements if the embedded storage will be used for processing classified information.

- g) Assign a static IP address for the device.
- h) Change all default password or Simple Network Management Protocol (SNMP) strings. Whenever possible, use SNMP v3.
- i) Only allow trusted hosts to manage the device. Disable unsecure protocols such as Telnet, File Transfer Protocol (FTP), Dynamic Host Configuration Protocol (DHCP), Hypertext Transfer Protocol (HTTP). Use Hypertext Transfer Protocol Secure (HTTPS) if remote management is needed.
- j) Enable secure network protocols and services (e.g. IPsec or Secure Internet Printing Protocol (IPP)) whenever possible to prevent unauthorised network interception.
- k) Access to file shares should be appropriately controlled (e.g. by password protection).
- l) Firmware should be upgraded as recommended by the manufacturer or support vendor.
- m) Enable audit logging and review the logs regularly.
- n) Use non-shared local printer to print classified documents, if available.

### 2.3.3 Technology

The increasing use of the Internet and collaboration tools, e.g., file transfer tools, cloud computing platforms, webmail, instant messaging, etc., increase the risk of unintentional, intentional and malicious leak of classified data significantly. It is impossible to track your data without relying on DLP systems. An effective DLP tool is indispensable for monitoring data at rest, data in motion and data stored in endpoint devices.

There are in general two types of DLP systems – Network DLP systems and Endpoint DLP systems.

### 2.3.3.1 Network DLP Systems

Network DLP systems provide broad protection for managed and unmanaged systems in the "Data in Motion" aspect. They monitor network traffic looking for specific data preventing the unauthorised transmission of data to the wider network.

Network DLP systems are also referred as gateway-based systems with the following characteristics:

- They are usually dedicated hardware/software platforms (or appliances).
- Install on the corporate network connection to analyse network traffic for unauthorised data transmissions.
- Integrate with or include technologies to discover "Data at Rest" while it is stored in file systems or databases.

The following are some major components of a network DLP system.

**Network Monitor:** Most network DLP systems deploy a passive network monitor at or near the network gateway and perform full packet capture, session reconstruction and content analysis in real time. It provides passive monitoring capabilities and generates alerts on unauthorised transmission of data.

**E-mail Integration:** E-mail integration is an obvious component for network DLP systems. An embedded MTA (mail transport agent) is added as another hop in the e-mail path to block, quarantine, encrypt or bounce back messages. One weakness is that it cannot inspect internally routed messages since e-mail do not route through the external MTA.

**Filtering/Blocking and Proxy Integration:** Other channels such as HTTP, FTP and IM are more difficult to block since the traffic is synchronous that requires real-time content analysis. By integration with gateways/proxies, a session analysis can be performed to reconstruct and evaluate the content before it is released. If the gateway includes a reverse SSL proxy, it can also sniff SSL connections.

### 2.3.3.2 Endpoint DLP Systems

Endpoint DLP systems, also known as Host-based DLP, run on endpoint workstations or servers and focus on where the data is stored or used in the first place. They use content discovery technologies to identify or monitor data in "Data at Rest" aspect such as file storage scanning or "Data in Use" such as endpoint device monitoring.

Endpoint DLP systems focus on each node that may cause data loss:

- Some residing agents have to be installed and run on workstations or servers.

- Able to address internal as well as external communications controlling data flow between groups or types of users such as e-mail and instant messaging communications.
- Able to monitor and control access to physical devices such as USB port or mobile devices.
- For some solutions, it can inspect data before it is encrypted.
- Some can also provide application controls to block attempted transmissions of classified data and provide immediate feedback to the user.

The following are some major components of an Endpoint DLP system.

**Remote Scanning:** Either a central policy server or dedicated scanning server that connects with storage repositories/hosts via network shares or other administrative access. Files are then scanned for any content violation.

**Server Agent:** A thin agent is installed on the server for content scanning. Agents can be tuned to limit performance impact and results are sent securely to the central management server.

**Endpoint Agent:** Installed at endpoints/workstations, these agents normally include other DLP functions such as USB monitoring/blocking.

**Application Integration:** Integration with document management system, content management system or other storage-oriented applications, often through customised agent.

An effective DLP solution should combine both of these two types of systems to provide comprehensive protection in both network and endpoint channels so as to give overall risk reduction in most scenarios. This combined protection approach is also known as the layers of defence principle. In the next section, we will discuss in details how this principle can be applied in different scenarios to prevent data loss.



### 3. Layers of Defence

Layers of defence is a security principle that security controls are implemented in different layers to form a synergy approach, such that to increase the effectiveness and efficiency in addressing security threats that may not be achieved by using a single layer of defence. As such, a two-level layers of defence: the network gateway level together with the departmental level (host-based level) security controls is recommended to fight against common security threats as below that may lead to loss, leakage or damage of classified data:

a) Known intrusions

Known intrusions refer to signature based attacks. Similar to virus, they are malicious behaviours initiated by attacker. They are designed to cheat the system/application to treat them as normal traffic/service request and to gain unauthorised access or divert unauthorised service request by exploiting the system vulnerability. This kind of attacks targets to both network and host. One of the common known signature based network attacks is buffer overflow that attacker initiates the attack by sending a large amount of unexpected data to a vulnerable component of a victim system. The other common signature based host attack is software virus. Those signature based intrusion can be detected by signature enabled next generation firewall (NGFW) personal firewall, anti-spam/anti-malware solution.

b) Zero-day web attack

A zero-day web attack is a malicious behaviour and severe threat initiated by attackers to exploit a vulnerability of the underlying system/application of a website that is previously undiscovered or undisclosed. The successful zero-day web attack could probably cause adverse impact to the victim's website, web application and data as the mitigation measure is yet to be developed until the zero-day attack is being discovered in security incident. Unlike intrusions by signature based attack, the zero-day web attack pattern is unknown which renders those signature enabled detection software to be failure to detect its existence. Advanced persistent threat (APT) would leverage zero-day web attack to introduce malware into victim's infrastructure with the aims at gaining ongoing access to dig out more valuable information without being discovered. As such security controls with behavioural analysis capability, such as anti-advanced persistent threat (Anti-APT), data loss prevention solution and application policy control, are effective security measures to counter the zero-day web attack in particular for APT. The definition of APT and general defensive measures for APT are provided in Annex B for reference.

c) Spear-phishing email attack

Spear-phishing email attack is malicious behaviour that an attacker uses social engineering techniques to acquire and send a spoofing e-mail that apparently comes from a trusted individual (e.g. users of recipient's organisation/company with certain authority). It is a targeted attack to a specific organisation with aims at seizing classified data for malicious purposes, or installing malware on victim computer to launch further attack to victim's network to dig out more valuable information. Due to the customisability and the stealth property, the spear-phishing email attack is not easy to be detected. Email security focused solution and security tool equipped with user behavioural analysis capability are effective security measures to counter spear-phishing email attack.

d) Offline data leakage

Offline data refers to data resided on a storage device that is not under operation state. For example data on media tape in housekeeping state, or data on disk of a shutdown computer. Offline data leakage could be a consequence of loss, theft or unauthorised access of storage device at non-operation state containing classified data. Device control policy and full disk encryption are security measures to address the threats of offline data leakage.

e) Mobile data leakage

Mobile data refers to data resided on a mobile device regardless the data and device state. It is one of the common attack targets from malicious attacker as mobile is prone to leak data throughout its and data lifecycle. One example is the loss or theft of mobile device that leads to unauthorised access of resided data. The other example is the installation of malware that leads to unauthorised seizure of resided data. Mobile device management solution provides a full-suite of capabilities, such as mobile device encryption, remote wipe and device and application policy control that can effectively counter the security threats to mobile.

f) Data leakage via removable media and printers

The uncontrolled use of removable media and printers poses risk of data leakage. The threat may involve classified information being transferred to removable media or printed out for unauthorised use. Endpoint DLP is a security measure that can address the threat.

Network gateway level security controls refer to security measures that can be considered in security perimeter, such as government central Internet gateway or departmental Internet gateway owned/managed by B/Ds. Whereas departmental level security controls refer to security measures that can be considered in B/Ds' Information Technology (IT) infrastructure such as local desktop and notebook computer, remote VPN notebook, and mobile phone/tablet. Basically, network gateway level security controls are implemented to counter security threats initiated from Internet such as network intrusion attack. They serve as the first layer of

defence to protect the security perimeter to ensure legitimate traffic can pass through and the internal network is shielded from direct attack which minimise the risk of successful network penetration attack. Departmental security controls serve as additional layer of security defence to protect B/Ds' IT infrastructure to counter security threats other than that of those initiated from Internet such as offline data leakage and mobile data protection.

The recommendation of security controls in the network gateway and departmental levels, where applicable, with the explanation of security controls functions and corresponding implementation and operation considerations are provided as guidance for B/Ds to select the security controls to meet the business need to address the mentioned common security threats. For details of network gateway level and departmental level security controls against the fore-mentioned six security threats, please refer to sections 3.1 to 3.6 for reference. The mapping of security controls corresponding to the security threats is shown below for easy reference.

|    | Threat Areas                                  | Addressed by:                                                                                         |                                                                                                                                                                      |
|----|-----------------------------------------------|-------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|    |                                               | Network gateway Security Controls                                                                     | Departmental level Security Controls                                                                                                                                 |
| a) | Intrusions by signature based attack          | <ul style="list-style-type: none"> <li>▪ NGFW</li> <li>▪ Anti-spam/Anti-malware Protection</li> </ul> | <ul style="list-style-type: none"> <li>▪ Personal Firewall</li> <li>▪ Anti-malware solution</li> </ul>                                                               |
| b) | Zero-day web attack                           | <ul style="list-style-type: none"> <li>▪ Web advanced persistent threat (APT) protection</li> </ul>   | <ul style="list-style-type: none"> <li>▪ Behaviour Monitoring</li> <li>▪ Application Policy Control</li> <li>▪ Endpoint DLP</li> </ul>                               |
| c) | Spear-phishing email attack                   | <ul style="list-style-type: none"> <li>▪ Email APT protection</li> </ul>                              |                                                                                                                                                                      |
| d) | Offline data leakage                          | N/A                                                                                                   | <ul style="list-style-type: none"> <li>▪ Device Policy Control</li> <li>▪ Full Disk Encryption</li> </ul>                                                            |
| e) | Mobile data leakage                           | N/A                                                                                                   | <ul style="list-style-type: none"> <li>▪ Device encryption</li> <li>▪ Device level policy control</li> <li>▪ Remote wipe</li> <li>▪ Anti-malware solution</li> </ul> |
| f) | Data leakage via removable media and printers | N/A                                                                                                   | <ul style="list-style-type: none"> <li>▪ Endpoint DLP</li> </ul>                                                                                                     |

In addition, the recommended security controls at departmental level to be implemented in local desktop and notebook computer, remote VPN notebook, and mobile phone/tablet by B/Ds are summarised in the table below for easy reference.

|    | Security controls                                                                                                                                                              | Local desktop and notebook computer | Remote VPN notebook | Mobile phone/tablet |
|----|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------|---------------------|---------------------|
| a) | Behaviour monitoring<br>(section 3.2.2.1 for zero-day web attack & section 3.3.2.1 for spear-phishing email attack)                                                            | √                                   | √                   | √                   |
| b) | Device level policy control<br>(section 3.4.2.1 for offline data leakage)                                                                                                      | √                                   | √                   | √                   |
| c) | Application policy control<br>(section 3.2.2.2 for zero-day web attack & section 3.3.2.2 for spear-phishing email attack)                                                      | √                                   | √                   | √                   |
| d) | Personal firewall<br>(section 3.1.2.1 for known intrusions)                                                                                                                    | √                                   | √                   | √                   |
| e) | Anti-malware solution<br>(section 3.1.2.2 for known intrusions)                                                                                                                | √                                   | √                   | √                   |
| f) | Endpoint DLP<br>(section 3.2.2.3 for zero-day web attack, section 3.3.2.3 for spear-phishing email attack & section 3.6.2.1 for data leakage via removable media and printers) | √                                   | √                   |                     |
| g) | Full disk encryption<br>(section 3.4.2.2 for offline data leakage)                                                                                                             | √                                   | √                   |                     |
| h) | Device encryption<br>(section 3.5.2.1 for mobile data leakage)                                                                                                                 |                                     |                     | √                   |
| i) | Remote wipe<br>(section 3.5.2.1 for mobile data leakage)                                                                                                                       |                                     |                     | √                   |

## 3.1 Known Intrusions

### 3.1.1 Network Gateway Level Security Controls

The possible security controls to address the threat of intrusions by signature based attack at network gateway level include the following which will be further elaborated:

- a) Next generation firewall; and
- b) Anti-spam/anti-malware protection.

#### 3.1.1.1 Next Generation Firewall (NGFW)

##### a) Function

NGFW is a firewall with packet inspection capability such as application-level inspection, user identification, intrusion prevention and threat intelligence. Some of the features are overlapped with intrusion detection system (IDS) / intrusion prevention system (IPS). NGFW and IDS/IPS are complement to each other instead of replacement for each other.

A NGFW inspects traffic by detecting the anomalies. Normally, the anomalies include known attack signatures, protocol anomaly by network behaviour analysis and threat intelligence (e.g. IP reputation). Advance persistence threat (APT) may include as part of NGFW but this feature will be discussed in other section. Also, NGFW provides the attack blocking feature and traditional firewall features such as access control by port/protocol, and advance security features including VPN connections, anti-virus, anti-spam, anti-malware, secure web proxy and user behaviour analysis.

##### b) Implementation considerations

The key objective of NGFW is integration of multiple security protections such that it provides same or better features of traditional firewall, anti-virus, anti-spam, IDS/IPS, web proxy in standalone. However, by considering the multiple tiers of defence, B/Ds should consider NGFW as an additional protection rather than replacement of existing protection such as IDS/IPS and anti-virus.

## c) Operational considerations

- User

Not applicable as the user does not require to perform any activities relating to NGFW. If there is any connection issue such as inaccessible for website, user should report this to designated IT staff.

- IT Staff

IT staff are responsible for administration of NGFW. The administration includes reviewing the detected attacks in timely manner, updating the policy of NGFW regularly, supporting the NGFW, applying emergency policy based on recommendation by security incident handling and integrating with other security measures such as monitoring tool, where necessary.

### 3.1.1.2 Anti-spam/Anti-malware Protection

## a) Function

Anti-spam (AS)/Anti-malware (AM) protection for network is a component attached to other security devices that detect and remove spam/malware by detection engine. An AS/AM solution for network gateway protection checks the presence of spam/malware based on the inspection capability of implemented solutions using the detection engines. For example, AS component in email gateway detects and blocks the suspicious spam mail while AM in web proxy inspects downloaded files and terminated the malicious download. The detection of AS/AM is based on the engine with vendor provided logic and/or customisation for fitting B/Ds' environment.

## b) Implementation considerations

Since AS/AM network solutions are presented as one of the features for security devices, resources, detection channels for common protocol (e.g. web, email, and ftp) and multiple AS/AM engines are the key considerations when implementing AS/AM solution. If there are three types of security devices, e.g. NGFW, web proxy and email gateway, B/Ds should consider enabling the AS/AM engines by different vendors for maximise the protection. Also, together with AS/AM endpoint solution, B/Ds should not use the same engine for detecting virus of both endpoint and network. In addition, it is important to have alert notifications as IT staff can take appropriate mitigation actions.

In addition, if the detection logic of AS (such as keywords, and blacklist/whitelist) and AM (such as known and unknown behaviour) can be customised for fitting B/Ds' environment, B/Ds should consider to define a baseline or template for maximising the true positive detection rate.

c) Operational considerations

- User

Not applicable as the user does not require to perform any activities relating to AS/AM network gateway level solution. If there is any connection issue such as inaccessible for website or missing email, user should report this to IT staff or designated person.

- IT Staff

IT staff are responsible for administration and operation of AS/AM network solution. Since it is generally presented as components of security devices, he/she should follow the defined operation procedures. Reporting and alerting are important as reports/alerts are important indicators for potential infected machine within B/Ds environment. Also, the detection engine and logic are the most critical detection components, it is important to configure the system having automatic update for the two components.

### 3.1.2 Departmental Level Security Controls

The possible security controls to address the threat of known intrusions at departmental level include the following which will be further elaborated:

- a) Personal firewall; and
- b) Anti-malware solution.

#### 3.1.2.1 Personal Firewall

- a) Function

Personal firewall is an application with function similar to network firewall and deployed to the devices such as endpoints and servers. In general, B/Ds may take reference to section 3 – Firewall of practice guide for internet gateway security for generic configuration and administration.

Personal firewall provides access control capability for both incoming and outgoing traffic by the device. Depending on the vendor, some personal firewalls can determine the process running and set the connection rules rather than network parameters such as IP address, port and protocol. For example, a personal firewall may allow outgoing email connections with network TCP port 25 for particular email process, and deny outgoing email access by other process.

b) Implementation considerations

Similar as network firewall, B/Ds should have a clear understanding of legitimate traffic. It may not be difficult for a server identifying the legitimate traffic as the traffic is normally specific and clearly defined. However, it could be a difficult task for endpoint devices as they may require multi-access to support daily operations.

Ideally, white-list approach is the best way for implementing personal firewall as only known connections are allowed. However, in practice, black-list approach may be appropriate for endpoints if the devices do not contain classified information. B/Ds should perform a risk assessment for selecting suitable approach and applicability for endpoints and servers.

Visible notification, e.g., pop-up window to user, is important for on-going operation such that user can report problems to IT staff to take corrective action to resolve network connection issues. Some personal firewalls may allow user bypassing the controls manually when alert pops up; B/Ds should consider the risk associated with this feature.

c) Operational considerations

- User

User should report connection issues to IT staff (or designated person) if there is noticeable performance impacts to daily operation in timely manner. Also, if there is any pop-up message or alert, user should report the message/alert to IT staff accordingly.

- IT Staff

IT staff is responsible for managing personal firewall and handling the problems reported by users. The management activities include reviewing the violation in timely manner, applying emergency access control based on recommendation by security incident handling procedures and ensuring the delivery of reports/alerts/logs. In addition, the problem by users may include modifying access rule due to operation needs such as introducing new application.

### 3.1.2.2 Anti-malware Solution

a) Function

Similar to anti-malware for network, the solution by departmental level provides the protection by installing application (or agent) to local desktop and notebook computer, and remote VPN notebook.



An anti-malware solution for departmental protection checks the presence of malware directly by the process running on local desktop, notebook computer, and remote VPN notebook. Similar to that of network gateway solution, it detects the malware and terminates the process depending on the policy by anti-malware solution.

b) Implementation considerations

By the concept of layer of defence, it is important to select the solution vendor which is not the same as network gateway level anti-malware protection such that the endpoint anti-malware solution acts as "last defence" if the first layer of defence does not work. In addition, it should be configured such that users do not have privileges to modify the settings of anti-malware solution and the regular update of software and signatures is enforced in a centralised manner. Also, as the detection/blockage is performed at endpoint devices, it may consume computational resource especially if the anti-malware includes advance feature such as user behaviour analysis. Although the detection engine and logic are not heavily dependent on the known signatures, it is still common that vendor provides threat intelligence and/or new detection logic to solution for better and updated protection. Therefore, B/Ds should enforce regular update from vendor website or internal centralised update server, especially for remote VPN notebook which may not operate in government network.

c) Operational considerations

- User

Users should report any performance issue to IT staff. Also, users should not try to modify the setting of anti-malware solution unless it is approved by designated IT staff. On the other hand, users should ensure the application regularly update by connecting to authorised source such as vendor website or internal centralised update server.

- IT Staff

IT staff are responsible for administration and operation. Most of the anti-malware solutions have capability of centralised management similar as anti-virus solution. IT staff should define and execute a proper reporting and alerting procedures when potential malware or numerous suspicious activities are detected.

## 3.2 Zero-day Web Attack

### 3.2.1 Network Gateway Level Security Controls

The possible security control to address the threat of zero-day web attack in particular APT at network gateway level is web APT protection solution which will be further elaborated.

#### 3.2.1.1 Web APT Protection

##### a) Function

Network gateway level web APT protection solution provides a central point security measure at the network perimeter to counter the threats of zero-day attack in particular related to Hypertext Transfer Protocol (HTTP) and/or Hypertext Transfer Protocol Secure (HTTPS). It provides real time web protection by scanning all incoming http and/or https traffic and blocking any identified threats to stop its propagation into the website, its underlying system and web application.

Network gateway level web APT protection has a sandbox/virtual machine function to examine the pass-through web traffic. When file attachment is detected, it will simulate the access to assess, and check if there is any harmful threats identified, such as modifying of system registry or call back to external command and control (C&C) servers. If it is a positive case, the file attachment will be blocked or quarantined at the gateway level without delivering to the web. In addition, an alert message will be sent to pre-configured recipients for follow up actions. The sandbox/virtual machine function is useful to identify new security threat of unknown pattern, such as zero-day attack, that renders signature based detection and protection tools failed to work. Besides, web APT protection supports white-list/black-list for explicitly defining the allowed and disallowed source to access to the protected web source, reducing the risk of infection and data exfiltration.

##### b) Implementation considerations

Depending on the adopted web APT protection solution, the sandbox/virtual machine function is either on premises-based or cloud-based. B/Ds shall not route the traffic to external sandbox/virtual machine for deep analysis if it contains classified information. B/Ds shall adopt the web APT solution with on premises sandbox/virtual machine instead. Besides, users and IT staff have to work together to define the white-list/black-list at the implementation stage and establish change mechanism for ongoing operation and maintenance.

HTTPS decryption is another consideration for deployment web APT solution. Nowadays, encrypted websites are widely adopted due to security concerns and regulatory requirements such that some zero-day attack may be hidden in the encrypted traffic using HTTPS protocol. Theoretically, HTTPS traffic inspection can be performed by the APT gateway that decrypts the incoming traffic for inspection. The safe traffic will be re-encrypted by the gateway and deliver to internal web users accordingly. Therefore, depending on the adopted solution, it is possible to inspect web users' personal information. A notice to web users is recommended such that they are aware of being inspected when surfing web site even if web pages are encrypted by HTTPS protocol.

c) Operational considerations

- Users

The network gateway level web APT protection solution should be transparent to users. No specific operational consideration is required.

- IT Staff

IT staff should receive appropriate technical training on the adopted web APT protection solution in order to get familiar with the operation, administration, support and maintenance tasks. In addition to monitor and follow up the alert from the web APT solution, IT staff should establish and execute a configuration backup and recovery procedure. Furthermore, Data Custodians should derive and maintain a white-list/blacklist of network address to allow/deny the access to the web under control at firewall or router respectively when required. Besides, IT staff should follow the security incident handling procedures for reporting/escalating of security incident of successful web APT attack. To verify and identify zero-day infection or even data exfiltration at computers, the support team may also have to acquire computer forensics skills or otherwise, the relevant outsourced services.

### 3.2.2 Departmental Level Security Controls

The possible security controls to address the threat of zero-day attack at departmental level include the following which will be further elaborated:

- a) Behaviour monitoring;
- b) Application policy control; and
- c) Endpoint DLP.

### 3.2.2.1 Behaviour Monitoring

#### a) Function

Departmental level behaviour monitoring provides detection of the abnormal activities such as zero-day attack. The zero-day attack during web access may bypass the detection at network gateway level if the device is not used within B/Ds environment such as a remote VPN notebook. Also, as the concept of layer of defence, behaviour monitoring provides the last defence if there is any missing detection at network gateway level.

Zero-day web attack has no heuristics or fingerprints to detect. Hence, a signature-based scanning tool cannot confront against this attack. But those attacks usually generate a similar attack or operation patterns which are quite different from the daily operation, for examples, some system files on the end-point device would be attempted to be modified abnormally. These unusual activities are generally caused by these attacks. Basically, behaviour monitoring learns the pattern of normal operations activities known as profiling, in addition to pre-defined malicious behaviour patterns. When it detects exceptional or unusual behaviour, it will trigger the follow up actions, such as sending out alarm or intercepting the suspicious activities.

#### b) Implementation considerations

Normally, a server acts as a centralised management for deployment and reporting the status of endpoint devices; an agent is installed on endpoint-devices for monitoring and immediate response. It should be configured such that users do not have privileges to modify the settings of the agents. In general, the endpoint deployment supports both manual and network deployment. Moreover, behaviour monitoring is one of the features or modules of the endpoint protection product and usually for monitoring the combination of the activities or behaviours as shown below:

- Modification of system settings or registry values;
- Modification of file contents or attributes;
- Attempt to format a storage or disk drives;
- Attempt to send executable content through email or instant messaging; (i.e. to avoid code injection, etc.);
- Start network communications (such as FTP, PING, etc.); and
- Known malicious behaviour.

## c) Operational considerations

- Users

Users should not attempt to modify the configured agent, ensure the agent is up and running, and to take follow up actions when alert is received. Users should also assist IT staff during troubleshooting, and attend the user training workshops.

- IT Staff

IT staff support the agent deployment, configuration setting, patches and updates. They also monitor the system alerts and conduct investigation when necessary, and support operation enquiry raised by users. The centralised server should also be backed up regularly with an up-to-date recovery plan in case of system failure.

### 3.2.2.2 Application Policy Control

## a) Function

Departmental level application policy control provides white-list or blacklist approach for allowing or prohibiting application access. Sometime, zero day attacks introduce new application running on victim machine. If the application can be run successfully, the data inside the victim machine may be leaked to the attacker.

When a user's web browser is attacked by zero-day web attack, the attack may initiate other malicious code to damage or steal information. In this case, application policy control could prevent unauthorised access of applications, such as downloading or sharing files through Peer-to-Peer (P2P), running port scan, hijacking through dynamic link library (DLL) control hooking. It can be enforced by some endpoint protection systems. This control can also avoid other kinds of attack due to misuse of the applications, especially P2P, which can leak data if sharing the classified files. Some adopted solution use the white-list or blacklist approach or together with behaviour monitoring for achieving prevention of unauthorised application access.

b) Implementation considerations

Application policy control is one of the features or modules of the endpoint protection product as described in section 3.2.2.1 b. In general, the endpoint deployment supports both manual and network deployment.

For the application policy definition, in general, static and dynamic approach will be adopted depending on the solution. Static approach means a list of applications defined which allows or prohibits running the applications depending white-list or blacklist approach. The list should be defined according to the B/Ds' business needs for endpoint devices. White-list approach is recommended as it prohibits running any applications not in the list which is a more effective and secure way to protect the system. For dynamic approach, abnormal application will be prohibited by anomaly detection such as behaviour monitoring and anti-virus/anti-malware solution. Nevertheless, B/Ds should identify the list of authorised applications and treat them as input for application policy definition.

c) Operational considerations

- Users

Users should not install or run any new application without prior approval by IT staff and keep the agent running. If there is any problem from the agent, report to IT staff immediately, and assist IT staff during troubleshooting. In addition, users should attend related training workshops. Furthermore, users would have to raise requests to an officer as designated by the B/D if there is a necessity for using new applications if the white-list approach is adopted by the B/D. Also, the designated officer should consider if the new applications are acceptable for a particular user or a group of users such that similar requests from other users are not required.

- IT Staff

IT staff should support the agent deployment, and system setting, patches and updates installation. They also monitor the violation, conduct trend analysis and conduct investigation if necessary. In addition, they support user's enquiries and problems.

IT staff should handle user requests for using new applications that is not in the authorised application list. Furthermore, B/Ds should regularly update the list of application such as removing end-of-support applications and adding new version of approved applications.

### 3.2.2.3 Endpoint DLP

#### a) Function

When an endpoint is attacked by zero-day web attack, one key objective from hacker is to steal information. DLP can help detect and stop classified data leaving outside the endpoint and/or security perimeter. Endpoint DLP can protect classified data from the data-at-rest and data in motion states especially for data in motion by web connections.

#### b) Implementation considerations

As a departmental level solution, B/Ds should select the technical solution that fits for existing environment such as operating systems (OS) and commonly used applications. In technical aspect, the identification of classified data is based on the known keywords, word phrases, graphic and file-based fingerprinting. B/Ds should identify them before implementing the solution in production environment. As a good practice, B/Ds should start the implementation by turning on data monitoring. By understanding the data flows, B/Ds could continually enhance the effectiveness of data protection strategies.

Furthermore, DLP incident handling and approval for sending classified data are important considerations because the classified data may be legitimate for sending to external parties with proper control including encryption. B/Ds should base on the operational needs and discuss with users whether it is appropriate for users self-manage or for departmental (central) control for allowing classified data sending out after considering the associated risks. For example, the adopted DLP solution detects a violation which a user has sent restricted data to the authorised contractor through web, but it is legitimated as it is an operational need and the data is encrypted. In this case, B/Ds should consider the factors such as user friendliness and risk of data loss to decide whether the authorisation of sending classified data is granted by users or managed by user's line management. If the authorisation is decided by users only, sufficient checks and balances mechanisms such as regular review by another staff should be in place for mitigating risks such as unnecessary information disclosure.

c) Operational considerations

- Users

User should not attempt to modify the adopted solution, make sure the agent running, and to take follow up action when alert is received. Users should also assist IT staff during troubleshooting, and attend users training workshop. Also, if there is new classified data, users (as the role of information owner) should notify IT staff for classifying the data as "classified data" if technically feasible. The DLP policies should be reviewed regularly by an officer as designated by the B/D and fine-tuned to an optimised state. A deliberate and iterative approach on reviewing the policies will realise benefits more rapidly, because the review processes involve the appropriate stakeholders, execute due diligence, and reduce impact due to proactive communication throughout the review and fine-tune process. Users should attend regular awareness training so that they are reminded of the "DOs" and "DONT's" when using the DLP system.

- IT Staff

IT staff support the agent deployment, configuration setting, patches and updates installation. They also monitor the alerts and conduct investigation when necessary, and support operation enquiries raised by users. The centralised server should also be backed up regularly with a current recovery plan in case of system failure. The IT staff should perform the data classification and data labelling when data is classified; and change policies on the DLP system if required. The regular awareness training for all stakeholders should be conducted by IT staff so as to remind the users "DOs" and "DONT's" when using the DLP system.

### 3.3 Spear-phishing Email Attack

#### 3.3.1 Network Gateway Level Security Controls

The possible security control to address the threat of spear-phishing email attack at network gateway level is email APT protection which will be further elaborated.



### 3.3.1.1 Email APT Protection

Network gateway level email APT protection solution, similar to web APT protection, provides a central point security measure at the network perimeter to counter the threats of spear-phishing email attack. It provides real time email protection by scanning the content of all incoming emails and blocking any identified threats such as malware attachment, harmful script and malicious uniform resource locator (URL) to stop their propagation to the email server and then to the final recipient to reduce the security risk of successful spear-phishing attack. Since the spear-phishing email is well-crafted and looks like from a legitimate sender, it is not easy to be identified in an environment that lack of email APT protection with users of low email security awareness.

#### a) Function

Similar to web APT protection solution, email APT protection has a sandbox/virtual machine function to perform deep analysis of email content by system emulation to identify and block/quarantine any unknown, new advanced malware and attachment file or malicious URL before they can reach the email system and the recipient with an alert message sending to pre-configured recipient for follow up actions. This can minimise the security risk that the email system and the recipient are compromised. In addition, email APT protection supports white-list/black-list for explicitly defining the trusted and untrusted sender sources respectively to reduce the security risk of successful spear-phishing attack.

#### b) Implementation considerations

Email APT protection can be on premises-based or cloud-based. Incoming emails shall not be routed to the cloud-based service providers for inspection and cleaning if they contain classified information. B/Ds shall adopt the on premises solution instead. If B/Ds adopt cloud-based email APT protection, B/Ds should define the service level requirement with contractual terms to reserve the right to conduct security audit to the outsourcing or external service provider to ensure proper security measures are in place to protect B/Ds emails being processed by the outsourcing or external service provider. Besides, users and IT staff have to work together to define the white-list/black-list at the implementation stage and establish change mechanism for ongoing operation and maintenance. In addition, it is possible to have false positive detection that is similar as other security solution for email such as anti-spam gateway. B/Ds should consider allowing the email quarantine feature, such that users can retrieve the suspicious emails and report to IT staff if the email is legitimated.

c) Operational considerations

- Users

The email APT protection should be transparent to users and user operation is minimal. In some occasion, false positive error of the email APT protection may block/quarantine emails and/or email attachment incorrectly. A user has to report the suspected cases to IT staff for follow up actions, such as release the blocked/quarantined emails and/or email attachment, where applicable, and modify the white-list/black-list.

- IT Staff

IT staff should receive appropriate technical training on the adopted email APT protection solution in order to be familiar with the operation, administration, support and maintenance tasks. In addition to the monitor and follow up the alert from the email APT solution, IT staff should establish and execute a configuration backup and recovery procedure. Furthermore, IT staff should implement a white-list/blacklist of senders approved by an officer as designated by the B/D to allow and disallow email delivery to the protected email system. Besides, IT staff should follow the security incident handling procedures for reporting/escalating of security incident of successful email APT attack. In case an outsourcing or external service provider is engaged, IT staff should ensure a proper contact and escalation procedures are defined.

### 3.3.2 Departmental Level Security Controls

The possible security controls to address the threat of spear-phishing email attack, similar to zero-day attack, at departmental level include the following which will be further elaborated:

- a) Behaviour monitoring;
- b) Application policy control; and
- c) Endpoint DLP.

### 3.3.2.1 Behaviour Monitoring

#### a) Function

Similar to Zero-day web attack, Spear-phishing email attack has no heuristics or fingerprints to detect. Hence, a signature-based scanning tool cannot confront against this attack. But the attack usually generates a similar attack or operation patterns which are quite different from the daily operation, for example, many users suddenly would be sending a lot of emails. These unusual activities are generally caused by the attack. Basically, behaviour monitoring learns the patterns of normal operations activities. When it detects exceptional or unusual behaviour, it will trigger the follow up actions, such as sending out alarm or intercepting the suspicious activities.

#### b) Implementation considerations

It should be implemented in combination with zero-day web attack because the malicious URL is one of the outcomes for successful spear-phishing email attack. Please refer to section 3.2.2.1 b for details. For email security, the authorised connections by email client should be identified and authorised, that is, only B/Ds' or government's email servers are allowed for connection. By this consideration, the solution may apply a stricter control such as alerting the connections to unknown email servers if technically feasible.

#### c) Operational considerations

- Users

The consideration should be in combination with zero-day web attack because the malicious URL is one of the outcomes for successful spear-phishing email attack. Please refer to section 3.2.2.1 c for details.

- IT Staff

The consideration should be in combination with zero-day web attack because the malicious URL is one of the outcomes for successful spear-phishing email attack. Please refer to section 3.2.2.1 c for details.

### 3.3.2.2 Application Policy Control

#### a) Function

The discussion of application policy control for zero-day web attack covers the same function as that of spear-phishing email attack such as P2P, white-list or black-list approach. Therefore, please refer to section 3.2.2.2 a for details.

b) Implementation considerations

For email security, B/Ds should identify the authorised email application (or email clients) and web-based email clients where appropriate. Similar as that of zero-day web attack, the known application should be included in the list of authorised applications. Please refer to section 3.2.2.2 b for details.

c) Operational considerations

- Users

The considerations are the same as that of zero-day web attack from user perspective except that the web-based channel is for retrieving email. User should use authorised email client to access government email service. For other consideration, please refer to section 3.2.2.2 c for details.

- IT Staff

The considerations are the same as that of zero-day web attack from IT staff perspective. Please refer to section 3.2.2.2 c for details.

### 3.3.2.3 Endpoint DLP

a) Function

The function is the same as that of zero-day web attack except the Endpoint DLP solution must be capable of inspecting email connection. Please refer to section 3.2.2.3 a for details.

b) Implementation considerations

In particular for emails, B/Ds should identify the authorised email application (or email clients) and web-based email clients where appropriate. As the adopted Endpoint DLP solution is application specific such that it supports different email clients. B/Ds should confirm that the adopted solution supports the email client being used by the B/Ds' users. For other considerations, they are similar as that of zero-day web attack, please refer to section 3.2.2.3 b for details.

c) Operational considerations

- Users

The considerations are the same as that of zero-day web attack from user perspective except the use of web channel for retrieving email. User should use authorised email client as it is protected with proper security control whenever possible. Furthermore, user should not use other email clients connecting the mailbox. For other consideration, please refer to section 3.2.2.3 c for details.

- IT Staff

IT staff should remove or disable the unused email client such as the default email client by desktop OS if there is no operational needs by B/Ds. If there are operational needs for installing unauthorised email client, IT staff should follow the proper change procedures as defined by B/Ds and provide the technical security measures where possible. For example, if the unauthorised email client is not in the support list of adopted solution, IT staff may counter-propose the supported email client to users instead. For other consideration, please refer to section 3.2.2.3 c for details.

## 3.4 Offline Data Leakage

### 3.4.1 Network Gateway Level Security Controls

Security controls at network gateway level is not applicable. Please refer to section 3.4.2 for departmental level security controls.

### 3.4.2 Departmental Level Security Controls

The possible security controls to address the threat of offline data leakage include the following which will be further elaborated:

- a) Device level policy control; and
- b) Full disk encryption.

### 3.4.2.1 Device Level Policy Control

#### a) Function

Device level policy control refers to the security hardening requirements. The policy should meet B/Ds' security requirements such as the baseline and system specific security controls. The function for departmental level protection is to establish and maintain the security hardening requirements, such as prevention on the use of USB storage, and enforce them as security standard across the B/D.

#### b) Implementation considerations

The device level policy control enforcement should be consistent across all applicable operating systems (OS). In particular, for the same patch level of OS, the device level policy should be the same unless there is technical constraint with exception approval obtained from authorised persons, such as head of the bureau/department. In addition, there should be a continuous monitoring to identify violation, such that IT staff can take appropriate actions to mitigate the issue before the violation causes materialised harm due to known problems. Ideally, reports and alerts should be available in timely manner especially for those systems processing/storing classified data.

#### c) Operational considerations

- Users

Users should be aware of any suspicious violation, and report the problem to data custodian as soon as possible.

- IT Staff

IT staff should implement the device level policy according to departmental requirements to cope with the latest security threats targeting to the devices. If there is any violation identified through reports/alerts, follow up actions should be taken timely according to the defined security process and procedure related to the device level policy control. Besides, some device level policy control solution may come with a centralised management tool. It facilitates the management of the device level policy such as update and status check of endpoints remotely. IT staff should regularly check the device status and enforce the update policy to devices in order to maintain [how about ensure] the compliance and identify non-compliance case for follow up actions.

### 3.4.2.2 Full Disk Encryption

#### a) Function

Full disk encryption (FDE) is a technical security control protecting the data resided on a disk at a non-operation state to against the data loss resulted from the theft of device or unauthorised data recovery. One of the benefits of full disk encryption is the mandatory encryption of all files regardless the data classification to avoid missing any important file due to user's discretion. The other benefit is the immediate data destruction feature by simply destroying the cryptographic keys to render the contained data undiscoverable. FDE encrypts every bit of the data for a whole disk instead of particular files. A cryptographic key is required, such as password or smartcard, for encryption and decryption process. Without the cryptographic key, the data resided on the disk cannot be decrypted. Cryptographic erase is an approach for data sanitisation, however, it is susceptible to risks such as vulnerable encryption algorithm, undeleted backup keys and sanitisation assurance problem. Before implementing such solution, B/Ds need to consider the associated risks and possible impacts. In general, cryptographic erase shall not be used alone as a sanitisation method, and shall be used in combination with other sanitisation and physical destruction methods for destruction of classified information.

#### b) Implementation considerations

FDE is not designed to prevent data loss while the disk is in operation state because the resided data has been already decrypted. Besides, some FDE solutions support master cryptographic key (other than the cryptographic key created by user) under centralised management. It is used to decrypt the disk in case end-user forgets the password or loss/damage the smartcard. The master cryptographic key (and its backup if applicable) must be protected securely and its access must be controlled on a need-to-know basis to prevent unauthorised decryption of disk to seize classified information. In addition, the FDE can use software-based or hardware-based approach. The software-based approach will consume system resources, such as CPU and memory heavily while the disk is in encryption and decryption process and may have performance impact to the users. The hardware-based approach will consume low or virtually no system resources, and thus, has no observable performance impact to the users.

c) Operational considerations

- Users

With FDE enabled, a user is required to provide a cryptographic key in form of either password or smartcard in order to boot up the system. Once the system is booted up, it will operate as the same as a non-FDE system, but performance will be a bit slower. Besides, the user is required to protect the cryptographic key and not to disclose to a third party. In addition, the user is required to consider data backup to prevent permanent loss of data due to the forgotten of cryptographic key if the master cryptographic key is not in place.

- IT Staff

IT staff should receive appropriate technical training on the adopted FDE solution in order to get familiar with the operation, administration, support and maintenance of the FDE. IT staff must observe and follow the security procedures, in particular the backup, use and protection of the master cryptographic key, where applicable, and the security incident handling procedures that handle disk decryption based on forgotten of cryptographic key reported by users. If decentralised management of FDE is adopted that master cryptographic key is not available, IT staff should advise users on how to perform data backup regularly to minimise the risk of data irretrievability resulted from forgetting the cryptographic key.

## 3.5 Mobile Data Leakage

### 3.5.1 Network Gateway Level Security Controls

Security controls at network gateway level is not applicable. Please refer to section 3.5.2 for departmental level security controls.

### 3.5.2 Departmental Level Security Controls

The possible security control to address the threat of mobile data leakage includes mobile device management (MDM) server and client which will be further elaborated.

The applicable area of the above security control: Mobile phone/tablet.



### 3.5.2.1 Mobile Device Management Server and Client

#### a) Function

A MDM solution involves a server which sends out management commands to the client e.g. mobile phone/tablet to perform various administrative and security control tasks such as mobile phone/tablet encryption, mobile phone/tablet and application policy control, remote wipe, and anti-malware solution. It offers benefit to centrally enforce and implement the security policy and control on the mobile phones/tablets.

- Device encryption

A MDM server can enforce and activate the data encryption feature of the enrolled mobile phones/tablets. It can prevent data leakage resulted from theft or loss of mobile phones/tablets and assure the confidentiality of the resided data.

- Device and application policy control

The MDM server can enforce and activate the security configuration settings of the mobile phones/tablets to comply with the organisational security policy such as password policy. Certain features of the mobile phones/tablets such as Wi-Fi or Bluetooth can be disabled/enabled. Mobile phones/tablets can be restricted from installing new applications via "Over-The-Air" update or applications installed on the mobile phones/tablets can be restricted from running by the MDM server to eliminate the risk of installing and running malicious software.

- Remote wipe

The MDM server can remotely erase all data on the lost or stolen mobile phones/tablets to prevent from personal or classified data leakage. The mobile phones/tablets enrolled this feature must in operation state with Internet connection, such that the MDM server can reach the devices and trigger the erasure process remotely.

- Anti-malware

Traditional MDM solution takes a full-device approach in the management of mobile phones/tablets. The solution enables the checking of mobile configurations against the pre-defined policies, tracking inventory and performing real-time monitoring and reporting. As MDM is developed to combat unintended loss of organisation data resulted from loss or theft of mobile phones/tablets, it might not be able to address the threats that brought forth malware and virus tailored to attack the mobile phones/tablets.

MDM and mobile security are the two considerations facing by the organisations if they allow accessing and handling organisational information via mobile phones/tablets. While the MDM is the management solution to prevent data leakage from lost and theft, Mobile Application Management (MAM) addresses the security issues of the applications installed on the devices. MAM manages and secures only those applications that are specifically developed to work with a particular MAM product and leave the non-organisational data on the device intact. Another advantage brought by mobile application containerisation is that, as organisation data is stored inside a contained environment under the containerisation application on the device, malware is not able to affect its operations and data, thus the data confidentiality and integrity is assured.

b) Implementation considerations

MDM software provided by different vendors have different features and functions. Selection of the MDM software should consider whether functions provided matching with the business requirements, needs and the cost involved. It should be aware that functions provided by the MDM software may not be applied to certain type or brand of mobile phones/tablets.

Depending on the exposing risk to a particular organisation, different solutions might be deployed. For example, when dealing with unintentional leakage of organisation data via loss or theft of mobile phones/tablets, it is handled by the inventory and data wiping features of MDM. However, as in the case of targeted devices malware and virus attacks, MAM provides the best defence to deal with the problem.

There is no silver bullet solution that suits all scenarios, B/Ds are recommended to undergo a threat and risk analysis to identify the exposing risk, and prioritise to implement relevant mitigation measures.

c) Operational considerations

- User

The operation of the MDM server should be transparent to users. Users should make use of the mobile phones/tablets to conduct the business tasks according to the established security policy. Training workshops should be conducted to users to educate them about the security awareness on and proper usage of mobile phones/tablets in compliance with the established security policy.

If there is a need to collect end-user's personal data, the purpose/nature and possible transference to other parties should be made known, and that consent shall be obtained from the data subject before the collection. Furthermore, it is important to make sure that the data collected is sufficient and no excessive for the purpose declared.

- IT Staff

IT staff are responsible for supporting the asset management, configuration setting, and patches and updates deployment. IT staff also monitor the anomalies and events occurred on the enrolled mobile phones/tablets, and investigate incidents when necessary, and support operation enquiries raised by users about their mobile phones/tablets

## 3.6 Data Leakage via Removable Media and Printers

### 3.6.1 Network Gateway Level Security Controls

Security controls at network gateway level is not applicable. Please refer to section 3.6.2 for departmental level security controls.

### 3.6.2 Departmental Level Security Controls

The possible security control to address the threat of data leakage via removable media and printers includes Endpoint DLP which will be further elaborated.

#### 3.6.2.1 Endpoint DLP

##### a) Function

The function is the same as that of zero-day web attack. Please refer to 3.2.2.3 a for details.

##### b) Implementation considerations

The implementation considerations are similar as that of zero-day web attack, please refer to section 3.2.2.3 b for details. For the best practice of logging of printing activities and file transfer activities to removable media, please refer to “Practice Guide for Security Log Management” for details.

##### c) Operational considerations

- Users

The considerations are the same as that of zero-day web attack from user perspective except the use of removable media. Staff should follow the procedures as defined by B/Ds and seek proper authorisation before storing minimum required classified data to removable media. For other

considerations, please refer to section 3.2.2.3 c for details.

- IT Staff

IT staff should follow the change procedures as defined by B/Ds to update the record of authorised removable media configured in the solution whenever appropriate. For other considerations, please refer to section 3.2.2.3 c for details.

-- ENDS --

## Annex A: Considerations on Server and Workstation Backup Plan

### Server Backup

Local server tape drive backup is recommended over backing up of multiple servers through the network as backing up through the network will be much slower and time consuming if the amount of data is very large.

It would be better to use the differential backup during night time on week days and use full backup on Saturday night, when no one will be accessing the server.

The following is a suggested labelling standard for backup tapes and the use of four sets of backup tapes is suggested:

|               |                                          |
|---------------|------------------------------------------|
| Format:       | <b>&lt;File Server&gt;_X_Day_N</b>       |
| <i>where</i>  |                                          |
| <File Server> | = name of the file server (e.g. ITSX001) |
| X             | = F / D (Full / Daily)                   |
| Day           | = Mon / Tue / Wed / Thu / Fri / Sat      |
| N             | = backup set no.(1 / 2 / 3 / 4)          |
| Example:      | ITSX001_D_Tue_1                          |

In this case, 24 unattended backup schedules need to be created. This means that the LAN/system administrator will just have to mount the tape (write enabled) before leaving the office for the day, and check that the backup runs are successful on the following working day.

With automatic tape changers with adequate slots, manual mounting of tapes can be less frequent, say once a week. The LAN/system administrator should check the logs of the backup runs daily to ensure that everything is running fine.

There may be a need to keep a tape for each month or any special occasion in a safe when documents need to be deleted every month.

For handling the backup media which contains classified information, the corresponding requirements and procedures shall be followed such as proper labelling, encryption, storage conditions, etc.

If the time required for backing up the server is too long that exceeds the site's allowable backup time frame, data on the production server to be backed up can be copied to a dedicated backup server and let the backup task run on the dedicated server. However, the security level of this dedicated backup server should be retained as the same of the production server to prevent any potential security breach or unauthorised access.

Server backup software is operating system version specific. Most backup software products also provide disaster recovery option for faster and more reliable system recovery.

### **Workstation Backup**

There are many ways to back up a workstation, common options include:

- a. Backup using local backup device  
Workstation data can be backed up as frequent as required. Users can take the active role for backing up their data. Or a scheduler can be used to back up the data to local backup device (e.g. tape drive) at regular intervals.
- b. Backup using workstation backup agent and central network backup  
Most server backup software products provide the function to back up data that reside on connected workstations. Workstation data can be backed up to the server backup device following the client backup schedule defined by the LAN administrator. This can be done without interruption to users after office hours or lunch time, but the workstation will have to leave powered on during the backup.
- c. Backup using central network backup with vital data copied to server  
Workstation data can be copied to a server and the server will be backed up according to its regular backup schedule. Users can take the active role for copying their data to the server. Or a scheduler can be used to copy data to the server at regular intervals to match with the backup schedule on the server.

## Annex B: Advanced Persistent Threats (APT)

Advanced Persistent Threat (APT) is a set of malicious applications or executables running in machines and / or network in stealth mode over a prolonged duration. Normally, data exfiltration and service interruption are two major objectives for intruder using APT as attack vector. It is a low profile and difficult to be detected. Generally, it targets to a specific industry, organisation or government agencies.

Some malicious code infections may be categorised as APT as it may have been presented for some time before detection. They may purposefully target specific B/Ds, seeking to gain access to the classified information they hold. This is different from other types of cyber security incidents, for example, Denial of Service attacks, which aim to prevent legitimate user access to online services. B/Ds are advised to consider the following best practices for defending APT:

### Proactive Planning

- Develop a security incident response plan for APT attacks to ensure the handling process is in a consistent and effective manner.
- Perform security risk assessment for information systems at least once every two years, and whenever possible, conduct APT detection exercise through network-based and/or host-based detector.
- Keep staff abreast of the emerging threats and the latest anti-APT techniques through regular security and awareness trainings.
- Remain vigilant and subscribe the daily security news and alerts service of the DPO as well as other security intelligence services.
- Include anti-APT requirements when selecting endpoint and servers protection software.

### Preventive Measures

- Apply the latest security patches and updates released by product vendors to the operating systems and applications of the information systems to prevent APT attacks through known issues or vulnerabilities.
- Enable anti-malware and/or anti-APT solutions to detect and guard all endpoints and servers against computer viruses, malicious codes and APT.
- Configure endpoints and servers properly with all unnecessary services or components removed or restricted, for example, blocking unnecessary system services and requests from unauthorised network ports.

- Adopt Intrusion Detection and Prevention System (IDPS) to monitor anomalous activities in the network, analyse for signs of possible suspicious attack, and attempt to stop the abnormal activities such as connecting known suspicious IP addresses and botnet servers.
- Implement the anti-APT solution to detect and block malicious payloads and specific types of attacks, such as malicious process call in operating systems, connection to botnet servers, abnormal data transfer to known suspicious IP addresses.
- Implement application whitelisting solution to protect against unauthorised and malicious programs executing on high risk computer.

#### Detective Measures

- Log and review security events and alerts generated by the security system, such as IDPS, anti-malware solution, anti-APT solution, Internet gateway, and firewall, to detect suspicious activities.
- Collect the logs of security events and store the logs in a centralised storage for log correlation and analysis as well as to prepare for forensic study in case of APT attacks.